A COMPREHENSIVE GUIDE ON FIREWALL OPERATIONS AND BEST PRACTICES

BEING A FIREWALL ENGINEER

AN OPERATIONAL APPROACH

SECOND EDITION, 2021

JITHIN ABY ALEX

BEING A FIREWALL ENGINEER.

AN OPERATIONAL APPROACH.

Second Edition, 2021

A Comprehensive guide on

firewall operations and best practices

Jithin Aby Alex

About the Author

Jithin Aby Alex, CISSP, CEH

Security Professional, having experience in managing security operations, implementing and handling major security solutions and products in various environments and regions. I have used my experience, professional connections, and publicly available information for writing this book. I thank you for purchasing this book and thanks for the support. I hope this book will be informative to you and I wish you all the best.

Please visit ***www.jaacostan.com*** *for my articles and technical write-ups.*

Copyright © Jithin Aby Alex

All Rights Reserved. No part of this publication may be reproduced, distributed, or transmitted in any other form or by any other means including photocopying or any other electronic or mechanical methods without prior written permission from the Author.

Disclaimer: Although the author has made every effort to ensure that the information in the book was correct at the time of writing, the author does not assume and hereby disclaim any liability to any party for any loss, damage, or disruption caused by errors or omissions, whether such errors result from negligence, accident or any other cause. The author makes no representations or warranties concerning the accuracy or completeness of the contents of this work. All the diagrams, IP addresses, numbers, names, etc. used in this book are only for illustration purposes. All the names, proprietary terms, reference links used here belong to the respective owners. All other trademarks are the

property of their respective owners.

“There is always room for improvement.”

Contents

1.0 Introduction
2.0 Who is a firewall Engineer?
2.1 Understand the Job description.
3.0 Know the Box
3.1 What is a Firewall?
3.2 How a Firewall works?
3.3 Firewall ranking and benchmarks
4.0 Types of Firewalls
4.1 Packet Filtering Firewalls
4.2 Proxy Firewalls
4.3 Stateful Inspection Firewalls
4.4 Application Layer Filtering Firewalls.
4.5 Next-Generation Firewalls
4.6 Firewall Vendors & Major Market Leaders
4.6.1 Cisco ASA Firewalls.
4.6.2 Cisco Firepower Threat Defense (FTD)
4.6.3 Checkpoint Firewalls
4.6.4 Palo Alto Firewalls
4.6.5 Fortinet Firewalls.

4.7 Firewall deployment modes
4.7.1 Routed Mode
4.7.2 Transparent Mode.
4.7.3 As VPN Gateway
4.7.4 In the Cloud
5.0 Firewall Management and Configurations.
5.1 Hardening the Device.
5.2 Device Security Hardening Standards
5.3 Daily tasks of a Firewall Administrator
5.4 Firewall Analyzers for making things efficient.
5.5 Real-World Applicability/Incidents
5.5.1 Implementing rules in a hurry.
5.5.2 Adding rules unprofessionally.
6.0 Change Management
6.1 Types of Changes
6.2 Change Management Roles and Responsibilities
6.3 Sample Change Request Form
6.4 Change Request Workflow: An Example

7.0 Summary

1.0 Introduction

The security landscape is rapidly evolving and changing. During the early 2000, most of the companies invest in their perimeter packet filtering firewall with big faith. To be frank, it was enough to do the job. But as time passes, various new cybersecurity challenges emerged, threat landscapes changed, threat actors and methods become very sophisticated. Traditional packet filtering technologies couldn't able to prevent the attacks. Fortunately, the firewall appliance market has been also evolved. Instead of verifying the 5-tuples (source and destination IPs, Source and Destination ports, and the protocol), the firewalls become more intelligent to take decisions and filtering of traffic based on application, identity, and various other parameters.

When it comes to network security, one of the major and critical devices that every organization implements is a Firewall. You may find hundreds of firewall products in different categories such as Next-generation

firewalls, Virtual firewalls, Appliances, Cloud-based, etc. A firewall is considered the basic element of network security. Well, having firewalls improves the security posture of your organization. However, that is not just enough. From a network security point of view, proper security can be achieved by having a combination of the right product with the right configurations, the right administrator, and last but not the least, the right management approach and processes. Firewalls along with other security solutions such as endpoint security make your defense-in-depth architecture strong.

Though there are no prerequisites for understanding the topics mentioned in this book, I assume the readers have a basic idea of IT and networking.

Please note that this book is not a configuration guide and is not written from a configuration point of view. This book gives you a broad overview of Firewalls, packet flows, hardening, management & operations, and the best practices followed in the industry. Though this book is mainly intended for firewall administrators who are

into the operations, this book gives a quick introduction and comparisons of the major firewall vendors and their products.

In this book, I have covered the following topics.

- Various Job roles related to Firewalls.
- What makes you a firewall expert?
- Know the major firewall vendors and their models.
- Understand the packet flow or order of operation in each firewall.
- Understand the different types of firewalls.
- Understand the daily tasks of a firewall administrator
- Understand device hardening.
- Guidelines on hardening the firewalls.
- Explains major hardening standards and compliances.
- Understand the Change Management process.
- Illustration on How to make a firewall change (incorporating

Change management process) with a real-world example.

Let’s get started.

2.0 Who is a firewall Engineer?

A firewall engineer is a person who is responsible for the configuration and operations of the firewall on a day-to-day basis. The routine tasks are adding or removing firewall rules, verifying the hardenings, troubleshooting connections, etc.

Besides knowing how to configure and maintain a firewall, the firewall professional should know advanced networking concepts in depth. A few expectations from a firewall professional are listed below.

1. Should know how various protocols or services work. Rules are implemented based on the IP, ports, and service details. If you are not sure how the service works, then it could be hard to troubleshoot. Note that, an efficient engineer should be able to troubleshoot and fix issues promptly.
2. Understand the packet flows. This is

very important. When you are dealing with a firewall appliance, you should know how that product process the packets. This is also handy during troubleshooting. For example, if there is an issue with some communication, you could be able to find out whether the issue happens after or before NAT.

3. Should know how to use protocol analyzers. Having good knowledge of tcpdump or Wireshark is handy.
4. Thoroughly understand the ISO/OSI model.
5. Should know various dependencies related to services, traffic flows, etc.
6. Should be able to foresee the effect of a change in the network. Very important, you may implement a change in the firewall but a small change could sabotage the entire network. Know what you are doing. If someone asks, why did you put this rule, and what is it for? Then you should be able to confidently answer the question.

7. Very important, must know the Change management process.
8. The above points are minimal skills required for an operational engineer. But if you work in the implementations, then you should know more knowledge on networking, protocols and integrations.

2.1 Understand the Job description.

I just added this section for pouring in some basic ideas on different job roles, especially for beginners. When looking for a job related to Network security or Firewalls, you might encounter different titles such as Firewall Engineer, Firewall Consultant, Firewall Specialist, Firewall Analyst, Firewall Expert, etc.

If you are a professional looking for a position, it’s best to go through the job description rather than the actual job title. Companies do create their definitions for the

job roles. Some job roles are very exaggerated as well. In short, all such jobs are looking for people with hands-on expertise in firewalls.

The Job responsibilities can be categorized mainly into three. Presales, Post-sales, and Operations.

In presales, the security professional will act as a consultant who will be more into designing the network architecture. This person should know firewalls from different vendors, should know the limitations and the differences. They will be working closely with the sales team.

On the other hand, a post-sales professional should know advanced configurations of the appliance and is considered to troubleshoot any issues promptly. This person will be keen on updating his knowledge on a particular product. Whenever there is an issue that cannot be solved by the Operations team, it will be addressed by the post-sales team. The person could be also a service delivery professional who is responsible for deploying new devices into the network.

Who is a Service Delivery professional?

The professional who will go and deploy a service or solution or a product in an environment before it is fully handover to the operations team.

In Operations, the professional will be handling the already deployed network devices or solutions. And should be handling the daily tasks such as adding a rule, troubleshooting an issue, making changes on existing configurations, etc. A professional in operations, most probably have a routine job.

Note that, within the job role, there could be classifications based on the professional's experience and skills. For example, a Level 1 engineer might have only read-only access to the firewall configurations, whereas a Level 3 engineer might have the highest possible access and possess good technical knowledge of the technology.

With that said, each organization is different and some companies with matured security practices might have implemented roles with the least privileges and in some smaller companies, one or two-person do the all.

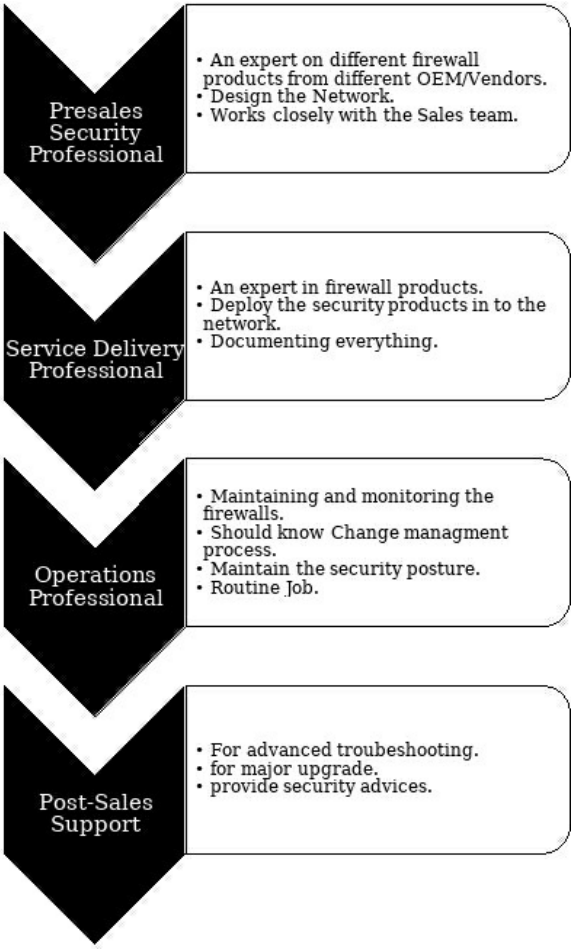


Figure: 1. Job roles

3.0 Know the Box

The first and most important thing about being a firewall professional is familiarity with the firewall product. Many learn the firewall through some videos or courses but haven't seen a firewall in real until they have started their job in networking.

Firewalls could be a physical appliance or they could be virtual, or even can be hosted in the cloud.

If you get an opportunity to set up a device from the scratch, do it. I have seen many experienced operational engineers but struggles when they moved to service delivery where they need to set up the device from the scratch. At some point in time, or during some emergency, you might be required to go to the data center to replace a firewall. The idea is, when you learn a product or solution, explore it and learn it completely.

3.1 What is a Firewall?

What is a Firewall?

As per RFC 2828, a firewall is "An internetwork gateway that restricts data communication traffic to and from one of the connected networks (the one said to be "inside" the firewall) and thus protects that network's system resources against threats from the other network (the one that is said to be "outside" the firewall)."

A firewall is a network security device that allows or rejects network access to traffic flows between an untrusted zone and a trusted zone.

It acts as the demarcation point in the network, as all communication should flow through it and it is where traffic is granted or rejected access. When it comes to perimeter security, a firewall is considered the first layer of defense. The firewall defines the perimeter. They enforce access controls through a positive control model, which

states that only traffic defined in the security policy is allowed onto the network and all other traffic is denied.

As mentioned, a firewall inspects the traffic flows between a trusted and untrusted zone. The zone that we need to protect is often referred to as the Inside or Trusted Zone. And the zone which is outside is often referred to as the Outside or Untrusted zone.

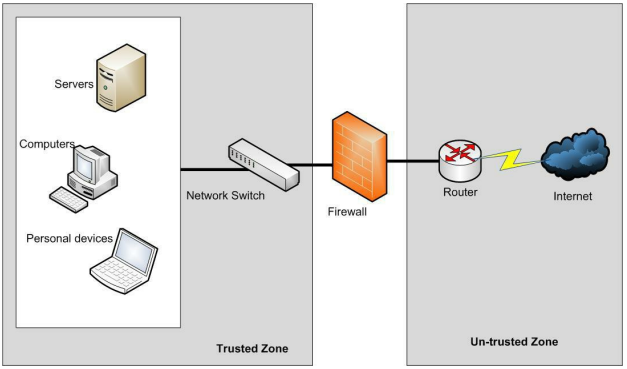


Fig: 2 Sample Topology

What is an Appliance?

A physical equipment which is made particularly for running the specific software is known as an appliance. Cisco's ASA firewall is an example for a Firewall appliance.

By the way, the term zone is just used for identifying the devices or area. For example, the Trusted Zone will have all the servers and other user laptops that need to be protected. Zone name can be anything and it is named under the discretion of the environment.

3.2 How a Firewall works?

A Firewall examines all the data packets passing through them to check if they meet the rules defined by the Access Control List (ACL) (rules) made by the firewall administrator. Only, if the data packets are allowed as per ACL, will be transmitted over

the connection. It is important to enabling logging for each rule and for the device itself. This is critical for troubleshooting as well as for various audit reasons.

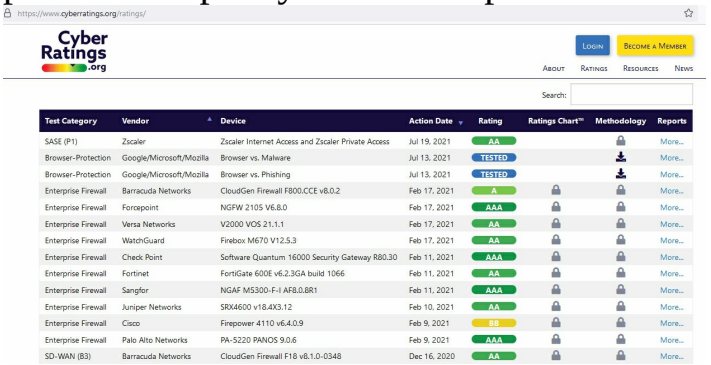
A Firewall can filter traffic based on IP Addresses, Protocols and services, Packet attributes, Connection state, and the application. In the following chapters, I have briefly explained how a firewall process a packet.

3.3 Firewall ranking and benchmarks

Many organizations, especially governments check the Gartner magic quadrant report for deciding on firewall purchase. Magic Quadrant (MQ) refers to a series published by IT consulting firm Gartner of market research reports that rely on proprietary qualitative data analysis methods to demonstrate market trends, such as direction, maturity, and participants.

You can explore more on Gartner MQ reports on https://www.gartner.com/

Also, if you want to compare the performance and efficiency of the firewalls, you can check the reports from CyberRating.org (https://www.cyberratings.org/ratings/). They perform the testing to validate a product's capacity to meet its promises.



Test Category	Vendor	Device	Action Date	Rating	Ratings Chart™	Methodology	Reports
SASE (P1)	Zscaler	Zscaler Internet Access and Zscaler Private Access	Jul 19, 2021	AA			More...
Browser-Protection	Google/Microsoft/Mozilla	Browser vs. Malware	Jul 13, 2021	TESTED			More...
Browser-Protection	Google/Microsoft/Mozilla	Browser vs. Phishing	Jul 13, 2021	TESTED			More...
Enterprise Firewall	Barracuda Networks	CloudGen Firewall F800.CCE v8.0.2	Feb 17, 2021	A			More...
Enterprise Firewall	Forcepoint	NGFW 2105 V6.8.0	Feb 17, 2021	AAA			More...
Enterprise Firewall	Versa Networks	V2000 VOS 21.1.1	Feb 17, 2021	AA			More...
Enterprise Firewall	WatchGuard	Firebox M670 V12.5.3	Feb 17, 2021	AA			More...
Enterprise Firewall	Check Point	Software Quantum 16000 Security Gateway R80.30	Feb 11, 2021	AAA			More...
Enterprise Firewall	Fortinet	FortiGate 600E v6.2.3GA build 1066	Feb 11, 2021	AA			More...
Enterprise Firewall	Sangfor	NGAF M5300-F-I AF8.0.8R1	Feb 11, 2021	AAA			More...
Enterprise Firewall	Juniper Networks	SRX4600 v18.4X3.12	Feb 10, 2021	AA			More...
Enterprise Firewall	Cisco	Firepower 4110 v6.4.0.9	Feb 9, 2021	BB			More...
Enterprise Firewall	Palo Alto Networks	PA-5220 PANOS 9.0.6	Feb 9, 2021	AAA			More...
SD-WAN (B3)	Barracuda Networks	CloudGen Firewall F18 v8.1.0-0348	Dec 16, 2020	AA			More...

Another famous option was NSS labs. NSS labs perform product testing and give a rating based on the performance. It does have a series of checks and validate the security effectiveness. Unfortunately, the firm, NSS labs shut down its operations in October 2020 possibly due to the impacts related to COVID19.

If you are a presales/sales engineer, or you want to purchase a firewall for your firm,

then it’s good to go through these reports and ratings to select a suitable product for your organization.

4.0 Types of Firewalls

Based on the functionality and usage, firewalls can be briefly classified into the following categories.

1. Packet Filtering Firewalls
2. Proxy Firewalls
3. Stateful Inspection Firewalls
4. Application Layer Filtering
5. Next-Generation Firewalls.

4.1 Packet Filtering Firewalls

Packet Filtering Firewall functions are normally deployed as Layer 3 devices such as Routers, Firewalls, etc. which connect the Inside network to the Outside. Packet Filtering Firewalls will check only the IP/port/protocol information.

Packet Filtering Firewalls work based on the rules defined in the Access Control Lists (ACLs). It checks all the packets and validates them against the rules defined in the

ACLs. In case, any packet does not meet the criteria then that packet will be blocked. This kind of filtering can be enabled in a layer3 switch or router as well. However, it does not offer great security. If the IP addresses are spoofed, packet filtering won’t be able to detect it.

4.2 Proxy Firewalls

Proxy firewalls act as middlemen as they accept all traffic requests coming into the network by impersonating the true recipient of the traffic within the network.

After an inspection, if it decides to grant access, the proxy firewall sends the information to the destination device. The reply from the destination is sent back to the proxy, which repackages the information with the source address of the proxy firewall. Simply the firewall does act as a proxy server. The chances of seeing a firewall as a proxy server in a real environment are very rare. This type of configuration was widely done during the '90s.

4.3 Stateful Inspection Firewalls

Stateful inspection, also known as stateful filtering, is considered the third generation of firewalls. Stateful filtering does two things:

Stateful Inspection firewalls monitor the state of the traffic. For example, when web traffic is initiated from inside to the outside (internet), the firewall checks the ACL and if it is allowed, then the state information will be stored on its State Table.

So, when the return traffic comes, the firewall checks its state table and if the traffic information already matches with the return traffic (i.e.; If a request for the incoming packet has been made by an internal host) then the traffic will be allowed to pass the firewall.

4.4 Application Layer Filtering Firewalls.

ALF is also referred to as Deep Packet

Inspection (DPI). This goes beyond the transport/session layer and up to the Application layer, therefore obliviously got the name Application layer Filtering. In this, the firewall inspects the application headers and the payloads. In short, the entire packet will be analyzed.

Many Next-Gen firewalls support this feature and it can automatically understand the kind of traffic and the applications. It is also possible to specify strict rules like only port 22 can be used by SSH. No other applications, other than SSH cannot use port 22 for communication. Such packets will be blocked by the firewall. This is to standardize the ports and their usage. If malware tries to exfiltrate some data over some standard ports, can be prevented to an extent if the rules are implemented correctly.

Since the inspections are rigorous in a firewall with application filtering enables, it requires more processing power.

One thing I need to add here is, there was a tool from Palo Alto for analyzing the existing rules and creating application

filtering rules. Some years back, my workplace had some Palo Alto firewalls and as part of hardening, we decided to enable application filtering. In Palo Alto terms, AppID. Since the rules were old and there were a lot of non-standard ports used for known protocols and services, doing it manually was hectic. We reached out to Palo Alto support and they have provided the migration tool. We host the tool in a VM and forward the logs to the tool. It also copies the rule base and compares the traffic against the rules. We let it run for some weeks. Almost all applications have been identified by the tool by analyzing the logs and then it pushes the cloned rule base with AppID enabled to the firewall. And now the firewall rules are enabled with application inspection. Note that, In the latest PANOS versions (Above 9.0), this can be achieved directly without using the external tools.

4.5 Next-Generation Firewalls

Next-generation firewalls (NGFWs)

were created in response to the evolving sophistication of applications and malware threats. These types of firewalls are widely implemented these days.

NGFWs act as a platform for network security policy enforcement and network traffic inspection. An NGFW consists of the following capabilities.

1) Standard capabilities of the previous generation firewalls that include packet filtering, stateful protocol inspection, network address translation (NAT), VPN connectivity, etc.

2) Integrated Advanced Intrusion Prevention System. Cisco ASA with Firepower service is an example of this.

3) Ability to enforce policy at the application layer independently from port and protocol.

4) Ability to take information from external sources and make improved decisions. Examples include creating blacklists or whitelists and being able to map traffic to users and groups using an active directory, or getting vulnerability and threat information from cloud services.

5) Integrate threat intelligence and enables integration with other security solutions such as SOAR tools, SIEM, etc.

Note: The firewall market is evolving and is competitive. Firewall vendors come up with catchy terms like next-generation, fourth-generation, or fifth-generation, etc. All they are trying is to be competitive by adding new functionalities and features. So if you see a firewall that is the fifth generation, signifies that it has some extra features than its previous generation. But are you going to use all its features in your organization? Well, the answer is maybe or may not. In defense in depth architecture, you deploy different layers of security solutions to screen the traffic and to limit the impact. As the first layer of defense, you might implement a perimeter firewall and instead of using the inbuilt Intrusion Prevention feature, you might implement a dedicated IPS device in your network.

Nowadays, the newer generation firewalls are equipped with features like Anti-Malware/Anti-Spam, Sandbox, etc. These

firewalls can perform a thorough analysis of every packet. Each of these features requires additional licenses as well. In the real world, you can see firewalls with application filtering enabled or with the base license, but not using any of its advanced features like sandboxing, antivirus, etc. However, they do implement dedicated security solutions for antivirus, endpoint security, email security, web security, etc. The idea is, don’t put all your eggs in one basket. Relying only on one firewall is not a good idea. Also, when one single device performs all the filtering and analysis, it creates a huge load as well. At the same time, if you have a branch site/small office/home office site with fewer users and you need to achieve good security, you can consider deploying such firewalls with all its features enabled.

What is Unified Threat Management (UTM)?

Unified Threat Management (UTM) devices are defined as the consolidation of stateful inspection firewalls, antivirus, IPS and various other features into a single appliance. They are mostly implemented on small networks.

Also, you might see networks with mixed vendors. For example, the perimeter firewalls are from Palo Alto and the DMZ firewalls are from the Checkpoint. This is a security tactic to reduce the risk appetite. If there is a known vulnerability that affects Palo Alto firewalls, but your critical infra in the DMZ is protected by Checkpoint and thereby reducing the risk level.

4.6 Firewall Vendors & Major Market Leaders

There are a huge number of firewall products from different vendors but the first firewall that most people will encounter could be probably Cisco's Adaptive Security Appliance (ASA). Though ASA are being obsolete, it is still being widely used in the industry. Cisco's security products are so popular and widely implemented across organizations around the world. Because of this popularity, when someone wants to learn networking or security, they start with Cisco products. But this doesn't mean that Cisco's Firewalls are the best. There are firewall products from Checkpoint, Juniper, Palo Alto, Fortinet, Cyberoam, Forcepoint, Sonicwall, McAfee, etc. Each one of them has its positive performance areas. However, when it comes to the enterprise market leaders on firewalls, the big names are Cisco, Checkpoint, PaloAlto. And Fortinet.

Therefore, in this section, I will be focusing more on the popular products, and in

the real world, a security professional will encounter at least one of these products in their career. Keep note that, most of the major vendors offer their firewalls as an Appliance, Virtual Machine, and a Cloud service.

Let’s get started with Cisco.

4.6.1 Cisco ASA Firewalls.

Cisco’s firewall product line started long back with PIX products. Later Cisco came with PIX’s successor, Adaptive Security Appliance (ASA). ASA is considered one of Cisco’s best and successful products. Cisco acquired another market leader Sourcefire and integrated it with their ASA product line. This made another set of product lines, named Cisco ASA with Firepower Services. They are also often referred to as their Next-Generation Firewall (NGFW). Cisco ASA (with Firepower services) is a security device that combines firewall, antivirus, intrusion prevention, and virtual private network (VPN) capabilities. It also provides proactive threat defense that stops attacks before they spread through the network.

The major ASA products are listed

below based on their capabilities. From the basic model to the top model. the Higher the models, the higher the capabilities on handling traffic and hence offers better throughput.

- Cisco ASA 5505
- Cisco ASA 5510
- Cisco ASA 5520
- Cisco ASA 5525
- Cisco ASA 5540
- Cisco ASA 5550
- Cisco ASA 5580

ASA with Firepower services product line comes with an appended X. Cisco ASA 5500-X with FirePOWER Services

- ASA 5506-X
- ASA 5508-X
- ASA 5516-X
- ASA 5525-X
- ASA 5545-X
- ASA 5555-X
- ASA 5585-X

Cisco’s ASA firewalls are running a proprietary Operating System. They are referred to as ASA images. Though ASA comes as an appliance model, though cisco does offer a Virtual ASA for virtualized environments and they call it as ASAv.

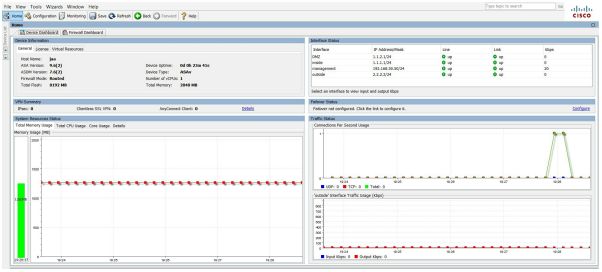


Figure 3: Cisco ASDM dashboard Sample.

Cisco ASA packet flow.

So here is a packet initiated from Inside to Outside (ingress to egress).

1) Assume, an inside user is trying to access a website located on the Internet (outside)

2) The packet hits the inside interface (Ingress) of ASA.

3) Once the packet reached ASA, it will verify whether this is an existing connection by checking its internal connection table. If it is an existing connection, the ACL check (step 4) will be bypassed and move to step 5.

ASA will check for the TCP flag if it is a TCP packet. If the packet contains an SYN flag, then the new connection entry will be created in the connection table (the connection counter gets incremented). Other than the SYN flag, the packet will be discarded and a log entry will be created.

Remember the 3-way handshake process. SYN/SYN-ACK/ACK. If the TCP connection flags are not in the order as it is intended to be, ASA will simply drop the packet. Most of the scanning/attacks are done by these flag manipulations.

If the packet is a UDP, the connection counter will get incremented by one as well.

4) ASA checks the packet again the interface Access Control Lists (ACL). If the packet matches with an allowed ACL entry, it moves forward to the next step. Otherwise, the packet will be dropped. (The ACL hit counter gets incremented when there is a valid ACL match.)

5) Then the packet is verified for the translation rules. If a packet passes this check, then a connection entry is created for this flow, and the packet moves forward. Otherwise, the packet gets dropped and a log entry will be created.

6) The packet is checked for the Inspection policy. This inspection verifies whether or not this specific packet flow complies with the protocol. In ASA we create these inspection checks through MPF (modular policy framework) or CLI using policy/class maps.

If it passes the inspection check, it is then moving forward to the next step. Otherwise, the packet is dropped and the information is logged. Additional checks will be done if the

ASA has a CSC module installed. The packet will be forwarded to that module for further analysis and returned to step 7.

7) Actual Network Address Translation happens at this step. The IP header information is translated as per the NAT/PAT rule. If an IPS module is present, then the packet will be forwarded to the IPS module for further check.

8) The packet is forwarded to the Outside (egress) interface based on the translation rules. If no egress interface is specified in the translation rule, then the destination interface is decided based on global route lookup.

9) On the egress interface, the interface route lookup will be performed.

10) Once a Layer 3 route has been found and the next hop identified, Layer 2 resolution is performed. Layer 2 rewrite of MAC header happens at this stage.

11) Finally, the packet will be forwarded by the ASA to the next hop.

Note: When a destination NAT is applicable, then there will be an additional step for that. Otherwise, the order of operation will remain the same.

4.6.2 Cisco Firepower Threat Defense (FTD)

In recent years, Cisco has come up with Firepower Threat Defense (FTD), which is a unified image of ASA and Firepower. It is designed to do what ASA and what Firepower can, together with unified management. Cisco FTD is capable of offering traditional ASA services plus NGIPS features, URL Filtering, Application visibility and control (AVC), Advance Malware Protection, ISE Integration, SSL Decryption, Captive Portal, and Multi-Domain Management, etc. So, from Cisco, the future of firewall offerings is based on FTD.

To manage a single FTD firewall, there is something known as Firepower Device Management (FDM). This can be related to ASDM which is used to manage Cisco ASA firewalls.

So, what about managing multiple FTD firewalls, for that, Cisco offers a product, known as Firewall Management Centre (FMC). FMC provides unified, single-pane management of Cisco firewalls and

associated products such as ASA with firepower services, Secure IPS, Malware Defense (AMP).

4.6.3 Checkpoint Firewalls

Checkpoint Software Technologies offers a wide range of Next-Generation Firewalls products. Checkpoint firewall software images can be installed on any compatible server. They also offer Firewall appliances. One of the best things about Checkpoint firewall is that their software offers a complete set of security features as different blades. You just need the appropriate license for activating the required feature. This can be compared to Cisco's FTD, which also offers various features in a single image.

Checkpoint GAIA is their next-generation secure operating system for all checkpoint appliances, open servers, and virtualized gateways, which makes GAIA a unified Operating System

Checkpoint Firewall Appliance models include,

- 1400 Series
- 3000 Series
- 5000 Series
- 15000 Series
- 23000 Series
- 44000 Series
- 64000Series

In figure 4, you can see the various software blades offered by GAIA OS.

- Firewall
- Application and URL filtering
- Data Loss Prevention
- IPS
- Threat prevention
- Anti-Spam and Mail
- Mobile Access
- IPSec VPN
- Compliance
- QoS
- Desktop

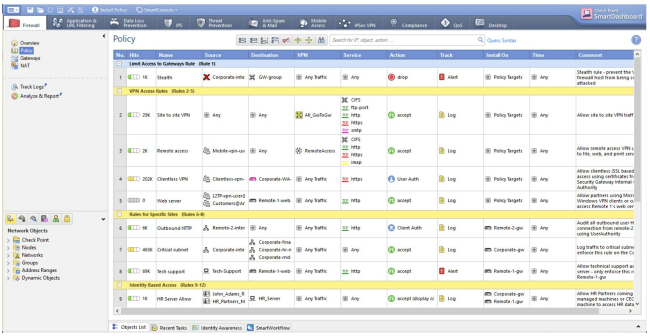


Figure: 4. Checkpoint Firewall Dashboard sample.

Product comparison links: -

https://www.checkpoint.com/check-point-security-appliances-comparison/

Checkpoint has another newer product called Quantum Next Generation Firewall Security Gateways that protects against different cyberattacks related to Network, cloud, IoT, remote users, etc.

Similar to Cisco's FMC, the centralized management of Checkpoint firewall is done using Checkpoint SMART-1 appliances, which is a single dedicated management server. This appliance consolidates security policy, log, and event management centrally.

Packet flow in Checkpoint.

A brief overview of how checkpoint process a packet is described below. Note that Checkpoint uses its terminologies for explaining its features and techniques under each step. For simplification's sake, I have omitted those and just provided a brief overview. You can see an in-depth explanation and analysis of the packet flow on the Checkpoint website.

1) Receive packet

If the received packet is encrypted, then the decryption will take place here.

2) State check

Check for the connection state.

SecureXL is a software acceleration product present in the Security Gateways. Performance pack uses SecureXL technology and other network acceleration techniques to deliver high-speed performance for Security Gateways. SecureXL is implemented either in software or in hardware. Depending on acceleration Settings and abilities, both individual packets and full connections can be accelerated through SecureXL. If acceleration is not possible, the packet is inspected through FW policy.

If the connection already exists, then the packet flow will proceed to step 7.

3) Firewall Policy rule check
4) Record a new connection entry
5) NAT policy lookup
6) Content inspection

The firewall check for all the threat identification and filtering options at this stage. If these features are not enabled on the firewall, then this step will be skipped.

- URL

- File integrity
- IPS signature
- Antivirus
- Threat inspection

7) Forward the packet

- Routing
- Source NAT if required.
- Encryption

8) Transmit the Packet

Finally transmitting the packet out of the firewall through the outbound interface.

4.6.4 Palo Alto Firewalls

If you ask me about the Palo Alto firewall, I will say this as “Configuration wise, one of the easiest and efficient firewalls that I have ever handled”. The GUI is great and very stable. The Palo Alto firewall runs its proprietary OS known as PAN-OS. They are currently considered the firewall market leader.

Palo Alto is one of the first vendors to introduce an application-aware firewall. Their

proprietary technologies include App-ID, User-ID, and Content-ID:

App-ID classifies known and unknown applications traversing any port and protocol via clear-text or encrypted SSL or SSH connections.

User-ID adds support of user and group policies through most all enterprise directories on the market in conjunction with the network-based User-ID agent.

Content-ID provides real-time content inspection and filtering, URL filtering, and IPS functionality.

It also has advanced features such as threat intelligence, Antivirus/anti-malware, sandboxing, etc. as well.

Use Palo Alto Panorama to manage all your firewalls from a centralized location. You can add your Palo Alto firewalls across the sites and can manage them through the single pane of glass, Panorama.

Packet flow in Palo Alto Firewall.

When a packet is subject to firewall inspection, it performs a flow lookup on the packet. A firewall session consists of two

unidirectional flows, each uniquely identified. In PAN-OS's implementation, the firewall identifies the flow using the following parameters:

Source and destination addresses: IP addresses from the IP packet.

Source and destination ports: Port numbers from TCP/UDP protocol headers. For non-TCP/UDP, different protocol fields are used (e.g., for ICMP the ICMP identifier and sequence numbers are used, for IPSec terminating on the device the Security Parameter Index (SPI) is used, and for unknown, a constant reserved value is used to skip Layer-4 match).

Protocol: The IP protocol number from the IP header is used to derive the flow key.

Security zone: This field is derived from the ingress interface at which a packet arrives.

1. **Initial Packet Processing**

   - Source Zone/Source Address: After the packet arrives on a firewall interface, the ingress

interface information is used to determine the ingress zone.

- Forward Lookup
- Destination Zone/Destination Address
- NAT policy evaluated
- For destination NAT, the firewall performs a second route lookup for the translated address to determine the egress interface/zone.
- For source NAT, the firewall evaluates the NAT rule for source IP allocation. If the allocation check fails, the firewall discards the packet.

2. Security Pre-Policy

- Check Allowed Ports
- Session Created

3. Application Check

- Check for Encrypted Traffic

- Decryption Policy
- Application Override Policy
- Application ID
- Application ID or App-ID does the application filtering.

4. Security Policy

- Check Security Policy
- Check Security Profiles

5. Post Policy Processing

- SSL Re-Encrypted
- NAT applied
- Packet forwarding

4.6.5 Fortinet Firewalls.

What Fortinet Says about their firewalls?

FortiGate Next Generation Firewall utilizes purpose-built security processors and threat intelligence security services from FortiGuard labs to deliver top-rated protection and high performance including encrypted traffic. FortiGate reduces complexity with automated visibility into applications, users and network and provides security ratings to adopt security best practices.

Fortinet firewall in the market is known as FortiGate and it runs its proprietary OS called FortiOS. Like PaloAlto, FortiGate firewalls are easy to configure and GUI is pretty. They also offer Next-Generation firewall products with robust security features.

Packet flow in FortiGate Firewalls

1) Ingress

When a packet is received by an interface, it goes through a set of security

checks.

- Denial of Service Sensor

If DDoS Sensor is enabled, determine whether this is a valid information request or is part of a DoS attack.

- IP integrity header checking

Reads the packet headers to verify if the packet is a valid TCP, UDP, ICMP, SCTP, or GRE packet

- IPsec connection check
- Destination NAT (DNAT)

DNAT takes place before routing so that the FortiGate unit can route packets to the correct destination.

- Routing

2) Stateful Inspection Engine

The stateful inspection looks at the first packet of a session and looks in the policy table to make a security decision about the

entire session. The stateful inspection decides to drop or allow a session and apply security features to it based on what is found in the first packet of the session.

- Session Helpers

FortiOS uses session helpers to analyze the data in the packet bodies of some protocols and adjust the firewall to allow those protocols to send packets through the firewall.

- Management Traffic

If the packet is identified as Management traffic, then Local management traffic is not involved in subsequent stateful inspection steps.

- SSL VPN
- User Authentication
- Traffic Shaping

If the policy that matches the packet includes traffic shaping it is applied as the

last stateful inspection step.

- Session Tracking

Just another name for the State table. The firewall maintains the State table.

- Policy lookup

The first stateful inspection step is a policy lookup that matches the packet with a firewall policy based on standard firewall matching criteria

3) Security Profiles scanning process

These are the Next Generation Firewall capabilities. Like other NGFW, FortiGate also checks for application layer details as well.

- IPS
- Application Control
- Data Leak Prevention
- Email Filter
- Web Filter
- Anti-virus
- VoIP Inspection

- Data Leak Prevention
- Email Filter
- Web Filter
- Anti-virus

4) Egress

After stateful inspection and other security inspections, the packet goes through the following steps before exiting.

- IPsec
- Source NAT
- Routing

Having a great understanding of the packet flow is very important and will be very useful during troubleshooting.

The final routing step determines the next-hop router to send the packet after it exits the FortiGate firewall.

4.7 Firewall deployment modes

A firewall in network infrastructure can be deployed in multiple ways. The NGFWs use different terms for these deployment modes and the terms vary with vendors.

4.7.1 Routed Mode

Most of the firewalls will be implemented in Routed mode and are considered as the popular deployment approach. In this mode, the firewall routes traffic between multiple interfaces, each of which is configured with an IP address and security zone.

If you want to utilize all the features of the firewall, then probably you might need to deploy your firewall in this mode.

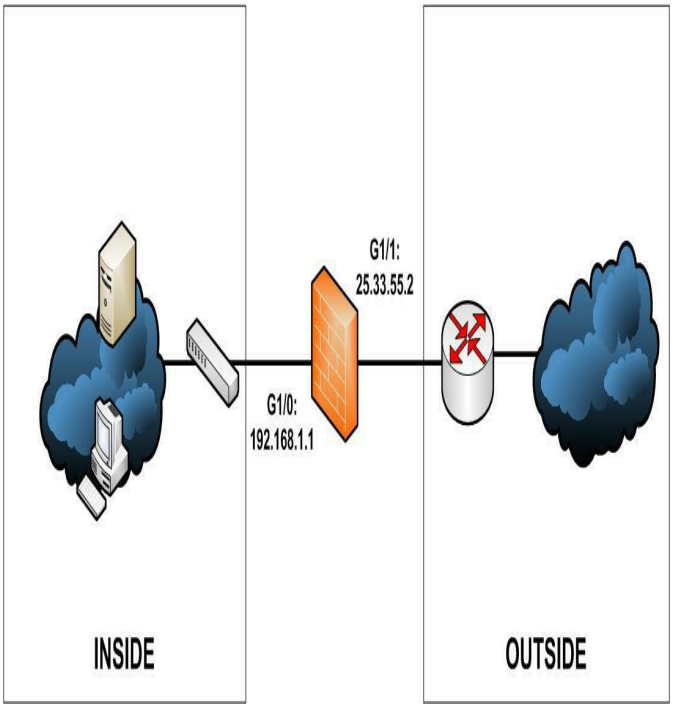


Figure 5: Firewall in Routed mode

4.7.2 Transparent Mode.

A transparent firewall, on the other hand, is a Layer 2 firewall that acts like a “bump in the wire” and is not seen as a layer 3 hop to connected devices. However, like any other firewall, access control between interfaces is controlled, and all of the usual firewall checks are in place. The firewall interfaces don’t have any IP addresses and the traffic

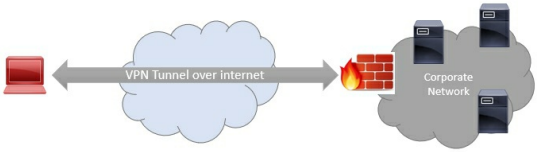
flow will happen through switching.

In PaloAlto, the transparent mode is more granular and you can deploy the firewall in a Virtual-Wire mode and this mode, the device will not interfere with Layer 3 and Layer 2 decisions. This means no routing and switching is being performed by the firewall.

4.7.3 As VPN Gateway

One of the notable uses of a firewall is to use it as a VPN gateway. You can set up a VPN in different ways. Site to Site, which connects two different sites and enables seamless access of resources over the network. Another option is to set up a client VPN for remote users. Users use a client to connect to your corporate network. Then establish the connection with the firewall which acts as your VPN gateway as well.

Cisco AnyConnect, Palo Alto GlobalProtect, FortiClient VPN, Remote Access VPN from Checkpoint at some of the widely used VPN client applications.


VPN Tunnel over internet
Corporate
Network

4.7.4 In the Cloud

Similar to the on-premises deployment of Firewalls, it can be also deployed in the Cloud. Some providers and vendors offer a Firewall-as-a-Service model (FWaaS). In this model, the firewall runs in the cloud and you can perform the configurations, create rules, etc. but a third party (most probably the provider itself) updates and maintains the device. You get access to the GUI/CLI to perform the routine tasks and forget about the underlying challenges such as updating the firmware, failover, etc.

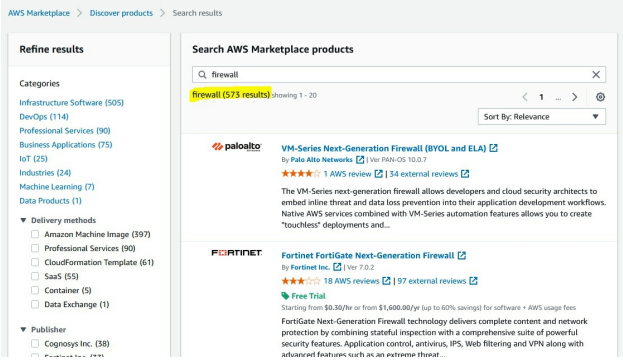
All the major vendors offer their products in the cloud as well. Cloud Firewalls are software-based solutions that can be used to control access to your cloud network.

Cloud firewalls can be easily integrated with the cloud infrastructure and can also leverage some of the cloud features such as scale up to handle more traffic.

Web Application firewalls (WAF) are quite famous with the cloud infrastructure. If you host some webservers, then you should protect them with a Web Application

Firewall. WAF is a dedicated product to address web-related attacks and threats. Cloudflare WAF, AWS WAF, Imperva WAF, Barracuda, F5 Advanced, etc are some of the famous WAF products.

Below one is the firewalls offerings from various vendors for AWS cloud. You can get any product that you wish from the marketplace and can deploy it in a few minutes.



5.0 Firewall Management and Configurations.

Management of firewall is recommended through a dedicated management interface and should be always out-of-band management. Though this might not be possible in all environments and infrastructure, you may often see firewalls configured slightly differently than the recommended best practices.

We can see the firewalls at various industries like Banking and Finance, the Health sector, educational institutions, Government, and private. Each sector may have some security compliance requirements to adhere and hence those standards/guidelines apply to the firewalls as well.

PCI-DSS: Payment Card Industry Data Security Standard

HIPAA: Health Insurance Portability and Accountability Act

CIS: Centre for Internet Security

For example, if there is a firewall in a financial institution that deals with users' financial information, may need to comply with the security recommendations from PCI-DSS. The device in a Health organization may need to comply with HIPAA compliance and some other organizations have their custom standards and some follow CIS standards and recommendations. I will focus on well-known CIS standards for illustrating some of the best practices that should be followed in a security environment.

5.1 Hardening the Device.

Hardening is usually the process of securing a device or System by reducing its

vulnerability risks or attack surface. Normally a firewall comes as a hardened device but some basic checklists should be followed on all devices including firewalls. This section lists the general security hardening standards.

- Services that are not needed shall be disabled.
- Dedicate a VLAN or an Interface for in-band Management. This VLAN/Port shall not be used to carry any user or data traffic except management traffic.
- Configure automatic logout for non-active sessions.
- Configure a banner to state that unauthorized access is prohibited.
- Disable telnet and utilize SSH for remote management of network devices.
- Use a strong SNMP community string that contains a minimum of 12 alphanumeric characters (with upper-lower-case combination and special characters).
- Implement port security to limit

access based on MAC address.

- Disable auto-trunking on ports.
- Disable/Shutdown un-used switch ports and assign them a not-in-use VLAN ID.
- Assign trunk ports a native VLAN ID that is not used by any other port.
- Limit the VLANs that can be transported over a trunk to only those that are necessary.
- Enable logging and send logs to a dedicated, secure log host.
- Configure logging to include accurate time information, using NTP and timestamps.
- Use AAA features for local and remote access to network equipment.
- Maintain the switch configuration file offline and limit access to it to only authorized administrators. The configuration file should contain descriptive comments to provide a perspective of the different settings.

5.2 Device Security Hardening Standards

1) Enabling and configuring AAA Services.

Authentication, Authorization, and accounting (AAA) provides an authoritative source for managing and monitoring access for devices. Centralized control improves the consistency of access control. The services are only accessible once the user is successfully authenticated, validate the access level (authorization). All actions of the users on the device are being logged as well (Accounting).

In addition, centralizing access control simplifies and reduces administrative costs of account provisioning and de-provisioning, especially when managing a large number of devices.

2) Access Rules

Default device configuration does not have stronger user authentication potentially enabling unfettered access to an attacker that

can reach the device. So, to prevent unauthorized access, the following guidelines can be considered.

- Set permission levels for different users and follow the principle of least privilege.
- Configure secure shell (SSH) access configured on all VTY management lines.
- Timeout for Login Sessions.

The device is configured to automatically disconnect sessions after a fixed idle time (less than 5 minutes. Lesser the better). This prevents unauthorized users from misusing abandoned sessions.

- Disable the Unused ports.
- Create management rules and ACLs for firewall management. Allow management traffic from defined IPs only.
- Whenever possible, implement a 2-factor authentication method to log

in to the device.

3) Password Management

Ensure that the firewall is configured with a standard security recommended password setting. Strong passwords with encryption shall be applied for privileged access to prevent any unauthorized users from accessing the device.

Always change the default account and password. In some devices, you may not able to delete the in-built root user, and in that case, change the default password with a more secured password.

In the case of Cisco, set the login and enable passwords. Also, set a master key passphrase which is used to encrypt the application secret keys contained in the configuration file.

Enable a Password policy.

- The password policy is used to prevent unauthorized access by enforcing the password for more complexity and making them difficult to be guessed.

- Minimum 12-character password with alpha-numeric-special character mix.
- Make sure that the password is not a commonly used word or name and should not be guessable.

Eg: **P@ssw0rd** is a guessable and commonly used password. Whereas **C@h#moOlTr!ha** is a Strong password.

- Create a password lifetime. Change the password every 30 days. This lifetime varies in different organizations.
- Restrict reuse of password. Prevent setting a previous password.
- Enable account lockout. If a login attempt is failed for three or five consecutive times, then disable the account for a certain period.

4) **Banner Settings.**

Network banners are messages that provide notice of legal rights to users of computer networks. This acts as a deterrent

for any unauthorized access. Appropriate banners should be configured during login on the device.

Sample Banner:

“USE OF THIS NETWORK IS RESTRICTED TO AUTHORISED USERS ONLY. USER ACTIVITY MAY BE MONITORED AND/OR RECORDED. ANYONE USING THIS NETWORK EXPRESSLY CONSENTS TO SUCH MONITORING AND/OR RECORDING. IF POSSIBLE CRIMINAL ACTIVITY IS DETECTED, THESE RECORDS, ALONG WITH CERTAIN PERSONAL INFORMATION, MAY BE PROVIDED TO LAW ENFORCEMENT OFFICIALS.”

5) Device Monitoring Settings.

The devices can be remotely monitored using protocols such as SNMP.

Simple Network Management Protocol (SNMP) provides a standards-based interface to manage and monitor network devices. This section guides the secured configuration of SNMP parameters. SNMP allows the management and monitoring of networked

devices. SNMP shall be disabled unless it is required for network management purposes.

- When SNMP is implemented, make sure that SNMP v1 and V2 are disabled and ensure that are using SNMPv3.
- Also, Define an SNMP access control list (ACL) with rules for restricting SNMP access to the device.
- Use SNMP traps rather than SNMP polling.
- Create SNMPv3 user with authentication and encryption options. Ensure only to use AES128, the minimum strength encryption method that should be deployed.

6) Clock Settings.

Configuring devices with a universal time zone eliminates difficulty during troubleshooting across different time zones and correlating time stamps for disparate log files across multiple devices.

Always sync the devices with an NTP

server. NTP server is a Clock server and all the devices configured to use the NTP server will have the same clock settings. This is very useful for correlating logs and other troubleshooting scenarios.

7) Service Rules

Services that are not needed shall be turned off because they present a potential space of attack and may leak out information that could be useful for gaining unauthorized access.

- Ensure use of SSH remote console sessions to devices. SSH encrypts all data as it transits the network and ensures the identity of the remote host.
- Disable SSH v1 and use SSHv2.

Some of the common services that should be disabled (unless it is used) are as follows.

- Disable bootstrap protocol (BOOTP) server.

- Disable Dynamic Host Configuration Protocol (DHCP) server.
- Disable the identification (identd) server.
- Disable auto-loading of remote configuration files from a network server. The protocols used to transfer configurations files, such as trivial file transfer protocol (TFTP) and file transfer protocol (FTP), are not secure
- Disable the FTP and use SFTP if needed.
- Enable transmission control protocol (TCP) keepalives-in/out service to kill abnormally terminated sessions.
- Disable trivial file transfer protocol (TFTP) server service.

8) Logging Settings.

Logging should be enabled to allow monitoring of both operational and security-related events.

- Enable logging to allow monitoring

of both operational and security-related events.

- Enable logging to device console and limit to a rational severity level to avoid impacting system performance and management.
- Designate one or more Syslog servers to centrally record system logs.
- Configure debug messages to include timestamps.
- Configure logging to include message timestamps.

9) Limit ICMP.

ICMP is used for monitoring/management and troubleshooting. At the same time, ICMP can be also misused for attacks. Appropriate settings should be applied to limit ICMP messages.

10) Enabling Authentication for Dynamic Routings where applicable.

Ensure that proper and strong authentication mechanisms are configured while using dynamic routing protocols.

11) Firewall Rules

- Add Comments/Remarks to Rules. Adding a clear description to every rule that shows ownership, date, and purpose of the rule, or a ticket reference, is important for identifying whether a rule is still required or could potentially be removed. This facilitates housekeeping and general management of the firewall rules. It is also recommended to include the Change Request (CR) number and the date of adding the rule in the comment section.

We will discuss more the Change Management process in the coming chapters.

- Remove Unused Filter Rule Sets. Unused filter rule sets make it harder to manage the rule sets effectively, as potentially active rules are still present, but they are not tied to an

interface, and therefore they do not have any effect.

- Remove Inactive Rules. Inactive rules make it harder to manage the firewall rule sets effectively. Set a time frame, for example, if a particular rule is not used for 6 months, then follow the appropriate Change Management Process and proceed with removing the inactive rule.
- Apply an Explicit Default Deny Rule. A default denies rule ensures that traffic without specific rules to permit it, will get denied by default. Nowadays, most firewalls have this feature enabled by default.
- Enable logging for all the Access rules.
- Restrict Internet Access to the Web Proxy rather than allowing direct internet or outside access. Allowing internal users to freely access the Internet could result in them accidentally visiting phishing websites or malicious websites

hosting malware which could lead to the compromise of the internal network. Hence it is better and recommended to have a Web proxy server for enhanced security and easy but efficient firewall ACL rule.

- Restrict Outbound Traffic from the Internal Network or DMZ. Overly permissive rules from the internal network to external sources could allow data to be leaked from the internal network, as well as allow compromised hosts to communicate with command-and-control servers. Outbound traffic from the internal network and DMZ should be restricted to the resources and services required by users to carry out their job.
- Review and audit the logs regularly.

5.3 Daily tasks of a Firewall Administrator

Some of the normal routine tasks of a

Firewall Engineer in an operations environment are mentioned below.

1) Adding/Removing/Modifying Firewalls Rules.

   This task will be done through a proper Change Management Process.

2) Back up the configuration.

   A firewall backup is crucial for recovery in case of a hardware failure.

   The backup of a firewall should be taken at regular intervals and should be stored in a safe and secured facility.

3) Troubleshooting connectivity issues.

   There will be so many instances where the users or devices face connectivity issues. So, the engineer should be good at performing the troubleshooting properly and quickly. Make use of logs and traffic flow to identify the issues.

4) Inspect firewall traffic and logs.

   Check for any major events like unauthorized login attempts, irregular traffic events, etc.

5) Check the firewall health.

   Keep an eye on the device’s hardware

health including CPU and memory utilization, temperature, Fan health, Storage, etc.

6) Adding new zones.

New zones and Interfaces may be added to the environment and the engineer should know how to configure these changes efficiently.

7) Keep track of network changes and diagrams.

- Any change in the network should be documented.
- Should follow the Change management process.
- Maintain Inventory of the Firewall or other network devices that you are assigned as the owner or administrator.

8) Proactive monitoring and action.

- Keep updating your knowledge and watch what is happening in the security world.
- Block any recommended spam

IP pools.

- Upgrade the firmware to patch the security issues.
- Reconfigure Crypto keys and passwords when needed.

9)

Useful Links and Best practices.

- Cisco ASA firewall best practices Guide: https://www.cisco.com/c/en/us/about/security-center/firewall-best-practices.html
- CIS Hardening guide for Cisco: https://www.cisecurity.org/benchmark/cisco/
- Checkpoint GAIA Hardening Guide: http://downloads.checkpoint.com/dc/download.htm?ID=37698
- PaloAlto Firewall CIS hardening Guide: https://www.cisecurity.org/benchmark/palo_alto_networks/
- Fortigate Hardening Guide: https://docs.fortinet.com/d/fortigate-hardening-your-fortigate-56/download

Configure and troubleshoot VPN configurations, if implemented in the environment.

5.4 Firewall Analyzers for making things efficient.

Assume that you are an administrator who handles multiple firewalls at different sites. If you want to review the rules, or compliance of the firewalls, how can you perform it?

If it's one or two firewalls, you could have done it manually. But when you have more than that, things get complicated and you might need to rely on third-party firewall analyzer tools such as AlgoSec, Firemon, Tufin, etc. I am not going to explain each product in this book. The idea is to give an introduction to the reader that, using firewall analyzers, you can achieve the following objectives,

1) Automated security policy management. Based on logs or incidents, it can suggest changes in the rules and can implement automatically.
2) When you have multiple firewalls from different vendors, you can manage the rules from a single pane of glass.

3) Can integrate with change management tools.
4) Can get the compliance report with firewall scores. It can check for weak rules and give mitigation advice.
5) Very much needed if you want to keep some audit/compliance requirements.

5.5 Real-World Applicability/Incidents

5.5.1 Implementing rules in a hurry.

One of the mistakes that lead to an incident is “being hurry”, a human error. The administrator might think of finishing the tasks as early as possible, maybe on a Friday night so that he/she can enjoy this weekend. During these kinds of situations, the administrator could miss some of the steps or due diligence and can result in issues. I will explain it with a simple real-world story.

Change management task: Configure SNMP on the firewall to send traps to the new set of SNMP servers.

Change requests have been submitted and were approved. The team has two members. The CR was submitted by the first engineer but on the day of implementation, the engineer was on leave. So, the second engineer was supposed to make the changes. Since it was a Friday evening, he implemented the rules to send SNMP traps on all 30+ firewalls at the same time. Since it is just a non-disruptive rule, that doesn’t cause any issues, the engineer was so confident to perform the operations. What went wrong was, the intranet Service provider didn’t open the ports. Since the SNMP traps logging level was configured as informational, every small information was sent to the SNMP server but has been blocked at the ISP end. It started replying to the ICMP unreachable error and firewall log it as another informational event and it created a vicious circle. 30+ firewalls sending millions of such packets in a short period created chaos and affected other resources in the network. Kind of DDoS attack.

But if you think, the rule is simple and should not cause any issue. The engineer also

thought the same and, in a hurry, it ends up in a major incident.

As the best approach, the engineer should have verified with the ISP whether they have opened the ports and implemented the change on one firewall, and observe for a few minutes before making another change could avoid this issue.

The takeaway from this is, the firewall administrator should follow the process with due diligence and act accordingly.

If you want to know more about this incident, read it here.

5.5.2 Adding rules unprofessionally.

Some engineers might be reluctant to follow the process correctly. They add the rules in the firewall but they don’t put the remarks/comments correctly. This results in vague description and as time passed, it

become very hard to track the particular rule to its original request.

During some audits, the auditors might sit next to you and ask you to go through the rules. And if they notice an empty or non-standard description, they might note it as non-compliance.

6.0 Change Management

Change management follows a set of processes and every detail about change is recorded for future tracking. Following the process ensures that there are no loopholes and change is validated to ensure successful deployment.

One of the most popular and most followed IT service management frameworks is ITIL. The Change Management process is designed to help control the life cycle of strategic, tactical, and operational changes to IT services through standardized procedures. The goal of Change Management is to control risk and minimize disruption to associated IT services and business operations. Change Management can help manage risk and safeguard the IT services you deliver and support against unnecessary errors.

So, what is a Change?

According to ITIL, a Change is "the addition, modification or removal of any authorized, planned, or supported service or service component that could affect IT services."

Many organizations make use of change management tools from ServiceNow, CA, etc.

6.1 Types of Changes

1) Emergency Change/Urgent Change

An emergency change must be assessed and implemented as quickly as possible to resolve a major incident

2) Standard Change

A standard change occurs frequently, is low risk, and has a pre-established procedure with documented tasks for completion. Standard changes are subject to pre-approval to speed up the change management process.

3) Major Change

A change that may have significant financial implications and/or be high risk. Such a change requires an in-depth change proposal with financial justification and appropriate levels of management approval.

4) Normal Change

A normal change is typically an important change to a service or the IT infrastructure. A normal change is subject to

the full change management review process, including review by the Change Advisory Board (CAB).

A typical Change Management Process includes the following activities:

1) **Create & Log the Request for Change (RFC)**

A Request for Change is typically created by the individual or business unit requiring the change. Depending on the type of change, an RFC record will contain varying information necessary to make decisions for authorization and implementation of the change, including, identifying information, a description, configuration item incurring the change, a reason for the change, requestor's contact information, type of change, timeframe, rollback plan, and business justification.

2) **Review Request for Change (RFC)**

Each Request for Change should be reviewed and prioritized by the change management authority. These requests can be rejected and returned to the submitter in the

request for more detail.

3) Evaluate the Change

Evaluating the change to assess the impact, risk, and benefits to IT services is critical to avoid unnecessary disruption to business operations.

Major points to be considered at this stage are,

1) What is the purpose of this change?
2) Justification
3) Impact of this change?
4) What is the rollback plan in case of any issue or failure?
5) Who is the person responsible for this change?

A Change Advisory Board (CAB) can evaluate changes. The CAB can consist of various stakeholders such as the service owner, technical personnel, and/or financial personnel to help evaluate the need for the change.

4) Approve/Authorize the Change

Change requests commonly require authorization before implementation and each

change requires authorization from the appropriate authority level depending on the type of change. This varies across organizations.

5) Implement the Change

Once the Change is approved by the authorized body, the CR (Change request) is scheduled for Implementation. This change implementation will be done by the Administrator. In our case the firewall administrator.

In big organizations, there will be a dedicated team for coordinating the Change implementation.

6) Review and Close Change Request

Upon completion of the change, a Post Implementation Review, which is a review of the detailed implementation results, should take place to confirm the change has successfully achieved its objectives. If successfully implemented, and the change was associated with fixing and error in service all associated problems and known errors should be closed. If not successful, the

remediation plan should be activated appropriately.

6.2 Change Management Roles and Responsibilities

Clearly defined roles and responsibilities lead to successful Change Management. Although each organization will determine its requirements, the following roles are typically found in the Change Management team:

1) **Change Requestor/Initiator**

The individual or business unit requesting a change.

2) **Change Advisory Board (CAB)**

A team of business, financial and technical representatives who assess the RFCs. The Change Authority is typically the head of a Change Advisory Board (CAB) and members may include personnel from Customer, Management, and technical sides. Each CAB meeting has an Agenda that prioritizes the change topics to be discussed.

3) Change Authority

The Change Authority is the owner of the Change Management process. This person reviews all change requests, rejects requests with insufficient information, leads CAB meetings. The change authority prioritizes and sets the decisions and outcomes of the CAB meetings.

Let’s summarize the entire process,

1) Requester submits a change request and if there are changes needed to be done on the Network (e.g.: Open a particular port or allow service through the firewall)

2) Submitted request is reviewed by the implementer and submits the change request form for the appropriate request to the network security manager and the Change Request Review team for review and approval.

3) Once approved, Implementer proceeds to do the changes and informs the requester once the change request is completed.

4) Monitor the Change and close.

In most organizations, this workflow happens through an online portal which is further integrated with a CMDB. A

configuration management database (CMDB) is a database that contains all relevant information about the hardware and software components used in an organization's IT services.

6.3 Sample Change Request Form

REQUEST INFORMATI	
Change Requestor	<Name of the Cha Requester>
Change Objective	<Objective of the
Change Description	<Detailed explana justification for the Ch
Organization	<Name of the Org
Location	<Location where be implemented>
Type of Change	<type of Change (normal/standard/eme
Business Impact	<Justify the busin the change>
Affected Service	<Affected service change implementatio
	<CI (Configuratic device in which the ch

Affected CI	implemented. If it is a specify the firewall ho identifier name>
Related Requests/Documents	<Any other inforr previous changes asso these current changes, here>
Details of Change Activities	<Detail explanati change is implemente
Date and Time of Service Resumption	<Change impleme
Rollback Plan	<Roll back plan i failure or issue>
Actual Plan Start date and time	<start time>
Actual Finish Start date and time	<end time>
Change Coordinated by (Team and Individual)	<Change Coo implementer details>

Implementation Review by (Team and Individual)	<Implementation or individual, if any>
Comments, if any	<additional comm

6.4 Change Request Workflow: An Example

One of the executives in an organization needs to access the business partner's newly launched website. This access is currently not allowed by the firewall.

Hence the executive or his business unit raises a request and it will reach the appropriate authority.

As a firewall administrator, I need to implement this change. So, beginning with the Change Management, I fill the Request for the Change (RFC) with all necessary details.

Assume the website, which the executive needs to access is https://www.xyz.com and His IP address is 192.168.10.20.

REQUEST INFORMATION	
Change Requestor	Jithin Aby Alex
Change Objective	Allowing access to Partner Web portal.
Change Description	Partner organization has a nev Web portal (https//www.xyx.com) that hosts important business data and access to that portal is required for the executive Mr.X
Organization	Sample Org Inc
Location	Sao Paulo
Type of Change	Normal
Business Impact	High
Affected Service	No Services are affected during this change.

Affected CI	SPFW001
Related Requests/Documents	FRCR.xls
Details of Change Activities	1) Backup the firewall configuration before the change 2) Implement the approved FRCR and CR. 3) Inform the Executive about the change. 4) Monitor the change
Date and Time of Service Resumption	19:00 ,15-September-2018
Rollback Plan	Revert the configuration in case of any failure.
Actual Plan Start date and time	19:00 ,15-September-2018

Actual Finish Start date and time	19:15 ,15-September-2018
Change Coordinated by (Team and Individual)	Firewall Admin Team, Jithin Aby Alex
Implementation Review by (Team and Individual)	Firewall Admin Team, Gerson
Comments, if any	Nil

FRCR.xlx attached with the RFC

Organization		MyOrganization			**E-mail**		**Jaa@xyy.com**
Requestor		Jithin Aby Alex			**Contact No :**		**12345678**
Department		IT					
Mr.X needs to access https://www.xyz.com							
S.NO	**SOURCE**	**DESTINATION**	**VALIDITY PERIOD**	**PROTOCOL/ PORT**	**DIRECTION**	**ACTION: ADD/REMOVE/DENY**	**Comment**
1	Mr.X PC 192.168.10.20	WebPortal https://www.xyz.com – 25.35.45.55	Permanent	TCP/443	Uni-directional	ADD	Access to the business website for the execurity Mr.X.

Submit the RFC to the CAB for review and approval. Once the RFC is approved, I can proceed with the change implementation on my firewall named SPFW001.

Please note that, when it comes to operations, processes and documentation matters more than technical knowledge. So, follow the process and document everything.

When the change is being implemented, that means when the rule is added in the firewall, mention the Change Request number and add the remarks for the rule. This enables to track the rules easily and even a newer administrator can able to identify the purpose of the rule and its associated documents.

7.0 Summary

This book covers an overview of the major firewalls in the market, different models, and the mode of operations. I also covered how the packet flow happens in each firewall. This book is intended mainly for firewall administrators who are into operations and explains the firewalls, technical flows, things to consider while hardening, understand the packet flow in different models, and how to make use of the change management process to implement a firewall change.

It is also important to keep your devices hardened. Even if it’s a firewall, it is important to keep it secure from unauthorized access, disable unused services, etc.

Along with technical knowledge, the administrator/engineer should have a thorough understanding of the process as well. The process varies for each organization. But adhering to the process is very important. Most of the major incidents that happen in the network are mainly due to

human errors.

If you are a beginner or a junior engineer, most of the firewall vendors are offering their courses for free and you can do it online, self-paced.

Note: All the diagrams, IP addresses, numbers, emails, etc. used in this book are only for illustration purposes. They don't represent anything other than illustration. The processes and hardening information that I have shared in this book is from real-world experience and is widely used among different organizations around the world.

All the proprietary terms used here are owned by the respective vendors and organizations. While writing this book, I made use of publicly available information for making firewall comparisons. I also collected opinions from various presales and technical personnel from different organizations. Showing one product better than another is not the objective of this book. Any personal comments that I made at certain sections about the pros and cons of some particular firewall are just based on

experiences and are applicable within that context.

I hope this book was informative to you and I wish you all the best.

Check my other works on Amazon.
Author page
amazon.com/author/jithinalex

Book	Description
	Palo Alto Cortex XSOAR: A Practica Buy from Amazon: **https://www.amazon.com/dp/B08Z4**
	Network Automation using Python Administrator's Handbook Buy from Amazon: **https://www.amazon.com/dp/B084C**
	Cisco Firepower Threat Defense (I NGFW: An Administrator's Handbo 100% practical guide on configurin managing Cisco FTD using Cisco FM FDM. Buy from Amazon: **https://www.amazon.com/dp/17268**
	Incident Handling and Respons Holistic Approach for an efficient Se

Incident Management.

Buy from Amazon:
https://www.amazon.com//dp/B089